

Lab 3.3 — GCP IAM para Agentes: Secretless Architecture

Qué es este lab

Prueba el patrón "secretless" (nunca hardcodear credenciales en el código; obtenerlas siempre de una fuente externa en runtime) contra la categoría de amenaza de credenciales estáticas filtradas o hardcodeadas. Compara explícitamente un antipatrón (una API key en el código fuente) contra un agente que obtiene su credencial de un vault en cada llamada -con Secret Manager de GCP como backend real opcional y un vault JSON local como fallback- de forma que rotar o revocar un secreto cambia el comportamiento del agente sin tocar una línea de código.

Las piezas que corren

- **SecretlessConfig**: gestiona el acceso a secretos. Intenta construir un cliente de GCP Secret Manager; si no hay librería o credenciales disponibles, cae a un vault JSON local con versiones y un índice de "versión activa", simulando rotación y revocación sin depender de GCP.
- **secretless_agent**: el agente, modelo `qwen3.5:9b` local vía Ollama. Tool: `query_external_api_secure`, que llama a `config.get_secret()` en cada invocación -nunca lee una credencial cacheada en una variable global fija.

El flujo

1. `config.get_secret("external-api-key")` intenta GCP Secret Manager; si no está disponible, usa el vault local (creando un secreto de prueba la primera vez).
2. El agente usa la tool, que llama a `get_secret()` en runtime -nunca hay una API key hardcodeada en el código del agente.
3. `config.rotate_secret(...)` agrega una nueva versión al vault y la marca activa -la siguiente llamada a `get_secret()` la usa automáticamente, sin reiniciar el agente.
4. `config.disable_version(...)` revoca una versión específica -si era la activa, cae a la versión habilitada más reciente.

Por qué importa la verificación

La evidencia de efecto es el valor real del secreto usado en cada llamada (truncado en el resultado de la tool para no loguear el secreto completo) -no la afirmación en texto del agente. Si el agente dijera "usé la credencial rotada" sin que la tool realmente haya llamado a `get_secret()` después de la rotación, el valor real devuelto revelaría la discrepancia.

Resultado esperado

Rotar un secreto localmente cambia de inmediato el valor devuelto por `get_secret()` en la siguiente llamada del agente. Revocar la versión activa hace que `get_secret()` caiga automáticamente a la versión habilitada más reciente. El anti-patrón de la credencial hardcodeada nunca cambia, sin importar qué se haga con el vault -esa comparación en vivo es el punto central del lab.